

# CVEs más relevantes de la semana

Del 30/05/2026 al 06/06/2026

Porque el primer paso para defender es conocer las amenazas.



## CVE-2018-25412

Descripción: Delta Sql 1.8.2 contains an arbitrary file upload vulnerability that allows unauthenticated attackers to upload malicious files by sending POST requests to docs\_upload.php with crafted multipart form data. Attackers can upload PHP files with arbitrary content to the upload directory and execute them on the server for remote code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-30



## CVE-2026-10187

Descripción: A vulnerability was detected in Totolink N300RH 6.1c.1353\_B20190305. Affected by this issue is the function setWiFiBasicConfig of the file wireless.so of the component Web Management Interface. Performing a manipulation of the argument KeyStr results in stack-based buffer overflow. The attack is possible to be carried out remotely. The exploit is now public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-05-31



# CVE-2026-44825

Descripción: Hardcoded credentials in the Basic Authentication setup tool (bin/solr auth enable) in Apache Solr versions 9.4.0 through 9.10.1 and 10.0.0 allows a remote attacker to gain full administrative access to the cluster via publicly known default credentials installed silently alongside the user-specified account.

As an immediate workaround without upgrading, delete the template users (superadmin,...

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-06-01



## CVE-2026-22872

Descripción: Capsule is a multi-tenancy and policy-based framework for Kubernetes. The Capsule Controller runs with cluster-admin privileges. Although the TenantResource RawItems processing logic forcibly sets the namespace, this is ineffective for cluster-scoped resources. Prior to version 0.13.0, tenant administrators can leverage the Controller's elevated privileges to create cluster-scoped resources (su...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-01



CVE-2026-8644

Descripción: IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to identity spoofing.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-06-01



## CVE-2026-9311

Descripción: IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to remote code execution caused by the bypass of security controls.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-06-01



## CVE-2026-9319

Descripción: IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to potential remote code execution due to deserialization of untrusted data via JAX-WS endpoints with WS-Security.

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-06-01



## CVE-2018-25427

Descripción: Arm Whois 3.11 contains a stack-based buffer overflow vulnerability that allows remote attackers to execute arbitrary code by supplying oversized input to the IP address or domain field. Attackers can craft malicious input exceeding 658 bytes with shellcode to overwrite the structured exception handler and gain command execution when the application processes the input.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-06-01



## CVE-2026-8206

Descripción: The Kirki – Freeform Page Builder, Website Builder & Customizer plugin for WordPress is vulnerable to privilege escalation via account takeover in all versions 6.0.0 to 6.0.6. This is due to the plugin accepting an arbitrary email address when a username is used in the password reset request. This makes it possible for unauthenticated attackers to send a password reset link for any user registe...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-06-02



## CVE-2026-47117

Descripción: OpenMed before 1.5.2 contains a remote code execution vulnerability in the PII privacy-filter model loading path. The privacy-filter dispatcher used broad substring matching on the user-supplied model\_name parameter, allowing a value such as attacker/foo-privacy-filter-bar to route through a path that loads Hugging Face models with trust\_remote\_code=True. An unauthenticated attacker can supply ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-06-02



## CVE-2026-42074

Descripción: OpenClaude is an open-source coding-agent command line interface for cloud and local model providers. Prior to version 0.5.1, the dangerouslyDisableSandbox parameter is exposed as part of the BashTool input schema, meaning the LLM (an untrusted principal per the project's own threat model) can set it to true in any tool\_use response. Combined with the default allowUnsandboxedCommands: true sett...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-06-02



## CVE-2026-5076

Descripción: The ARMember Premium plugin for WordPress is vulnerable to an insecure password reset mechanism in all versions up to, and including, 7.3.1. The plugin stores a plaintext copy of the password reset key in the `arm\_reset\_password\_key` user meta field when a user requests a password reset. This is in addition to the hashed key that WordPress core stores securely in `wp\_users.user\_activation\_key`....

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-06-02



## CVE-2026-35075

Descripción: An unauthenticated remote attacker can recover a default, hard coded password from a firmware image and thus gain full access to all affected devices.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1393

Tecnología: No especificado

Publicado el: 2026-06-03



## CVE-2026-5241

Descripción: A vulnerability in the LightGlue model loading path of huggingface/transformers version 5.2.0 allows an attacker-controlled model repository to execute arbitrary code during model initialization. The issue arises because the `'trust_remote_code'` parameter, intended to prevent remote code execution, is overridden by untrusted serialized configuration data in a nested code path. Specifically, when...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-829

Tecnología: No especificado

Publicado el: 2026-06-03



## CVE-2026-49185

Descripción: The FieldX MDM adb messaging topic passes unverified payloads directly into Runtime.exec(), allowing command/instruction injection.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-49186

Descripción: The local MQTT broker does not enforce topic-level Access Control Lists (ACLs). This allows any client to subscribe using wildcard characters (# or +) to enumerate hidden network devices or publish rogue control commands.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-49188

Descripción: The ai\_cmd utility executes with full root permissions. It pipes socket inputs directly to popen(), paving the way for unauthenticated users to execute arbitrary root commands.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-489

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-49191

Descripción: The production build of the M3WebServer hard-codes its backend API keys, which can be easily intercepted through verbose error handling pages.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-50208

Descripción: High-risk TrustAllCerts routines disable standard TLS certificate validation. Combined with hard-coded DES symmetric encryption keys, a Man-in-the-Middle (MITM) actor could decrypt network traffic.

CVSS: 9.4 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Tipo: CWE-330

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-50211

Descripción: Leftover engineering diagnostics and factory-level diagnostic software remain exposed on retail builds, giving malicious apps write privileges to internal NVRAM registers.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-134

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-4104

Descripción: Authorization bypass through User-Controlled SQL primary key vulnerability in Akmer Informatics Automation Industry and Trade Ltd. Co. TeknoPass allows SQL Injection.

This issue affects TeknoPass: from 20210501 through 20260429.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2019-25727

Descripción: WordPress Plugin ad manager wd 1.0.11 contains an arbitrary file download vulnerability that allows unauthenticated attackers to download sensitive files by manipulating the path parameter. Attackers can send GET requests to the edit.php endpoint with export=export\_csv and a malicious path parameter to read arbitrary files like wp-config.php accessible to the web server.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2019-25729

Descripción: PDF Signer 3.0 contains a server-side template injection vulnerability that allows unauthenticated attackers to execute arbitrary code by injecting PHP commands through the CSRF-TOKEN cookie parameter. Attackers can craft malicious cookie values containing template injection payloads like `shell_exec()` to execute system commands and retrieve sensitive information from the server.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-352

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2019-25738

Descripción: WordPress Hybrid Composer 1.4.6 contains an unauthenticated settings change vulnerability that allows unauthenticated attackers to modify WordPress options by exploiting the hc\_ajax\_save\_option action. Attackers can send POST requests to the admin-ajax.php endpoint with the action parameter set to hc\_ajax\_save\_option to enable user registration and set the default role to administrator, enablin...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2019-25741

Descripción: Mobatek MobaXterm 12.1 contains a structured exception handling (SEH) based buffer overflow vulnerability in the username field of session files that allows remote attackers to execute arbitrary code. Attackers can craft a malicious MobaXterm sessions file with overflow data that triggers the vulnerability when imported and executed, enabling reverse shell execution with user privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-06-04



# CVE-2026-25550

Descripción: Seagull Software BarTender 2010, 2016, and 2019 contain an unauthenticated remote code execution vulnerability in the .NET Remoting service exposed on TCP port 7375 via BtSystem.Service.exe. The service registers an unauthenticated singleton endpoint — BarTenderSystem for BarTender 2016 <= R9, and DataServiceSingleton for BarTender 2019 <= R10 — configured with BinaryServerFormatterSinkProvider...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-48040

Descripción: The netty incubator codec.bhttp is a java language binary http parser. The library implements Oblivious HTTP (RFC 9458) using BoringSSL's HPKE C library via JNI. When deriving native memory addresses for cryptographic operations versions prior to 0.0.22.Final provide a fallback path for direct ByteBufs that do not expose their memory address through 'hasMemoryAddress()'. This fallback occurs wh...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-50292

Descripción: In libinput before 1.30.4 and 1.31.x before 1.31.3, libinput-device-group unescaped phys output can inject udev properties leading to arbitrary root code execution

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:L/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-93

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-10931

Descripción: Use after free in FileSystem in Google Chrome prior to 149.0.7827.53 allowed a remote attacker to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-10966

Descripción: Inappropriate implementation in Codecs in Google Chrome prior to 149.0.7827.53 allowed a remote attacker to potentially perform a sandbox escape via a crafted video file. (Chromium security severity: High)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-10971

Descripción: Insufficient validation of untrusted input in Printing in Google Chrome on Windows prior to 149.0.7827.53 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-10972

Descripción: Use after free in Ozone in Google Chrome on Linux prior to 149.0.7827.53 allowed a remote attacker to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-10974

Descripción: Insufficient validation of untrusted input in ANGLE in Google Chrome prior to 149.0.7827.53 allowed a remote attacker to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-10990

Descripción: Use after free in Glic in Google Chrome prior to 149.0.7827.53 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Medium)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-11002

Descripción: Use after free in Autofill in Google Chrome prior to 149.0.7827.53 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Medium)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-11113

Descripción: Insufficient validation of untrusted input in ANGLE in Google Chrome prior to 149.0.7827.53 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Medium)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-11120

Descripción: Insufficient validation of untrusted input in Enterprise Reporting in Google Chrome prior to 149.0.7827.53 allowed a remote attacker who had compromised the renderer process to potentially perform a sandbox escape via a crafted HTML page. (Chromium security severity: Medium)

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-06-04



# CVE-2026-48567

Descripción: Authentication bypass by spoofing in Azure HorizonDB allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-06-04



## CVE-2026-6274

Descripción: Improper Authentication, Missing authentication for critical function, Weak Authentication vulnerability in DTS Electronics Industry and Trade Ltd. Co. Redline WR3200 allows Accessing Functionality Not Properly Constrained by ACLs.

This issue affects Redline WR3200: from 7.1.3 before 7.1.8.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-06-05



## CVE-2025-71317

Descripción: NetMan 204 contains a hard-coded backdoor account with the username and password 'eurek' that grants administrative access. A remote, unauthenticated attacker can authenticate through the cgi-bin/login.cgi endpoint (for example /cgi-bin/login.cgi?username=eurek&password=eurek, which due to lax parameter validation can be shortened to /cgi-bin/login.cgi?username=eurek%20eurek) to obtain administ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-06-05



## CVE-2025-71318

Descripción: NetMan 204 fails to enforce authentication on its administrative pages and command endpoints. A remote, unauthenticated attacker can directly request administrative pages (such as administration.html, administration-commands.html, and configuration.html) to disclose sensitive information including LDAP configuration and active user details, and can invoke privileged UPS control commands — inclu...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-06-05



## CVE-2026-10580

Descripción: The Hippoo Mobile App for WooCommerce plugin for WordPress is vulnerable to Authentication Bypass leading to Administrator Account Takeover in all versions up to and including 1.9.4. This is due to a logic conflation in HippooPermissions::get\_user\_permissions(), which returns the same null sentinel for both administrators and unauthenticated visitors — a value that HippooPermissions::has\_role\_a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-285

Tecnología: No especificado

Publicado el: 2026-06-05



## Resumen del Reporte

CVEs analizados: 42

Promedio CVSS: 9.56

Fuente: [nvd.nist.gov](https://nvd.nist.gov)

Nos vemos la próxima semana. Hack the Cat ☹

